3.7.2 Authentication strength and usability

While the NIST AAL system is widely used, I like to use the strength-and-usability pyramid shown in Figure 3.9. The pyramid shows commonly used authentication methods, from weakest at the bottom to strongest at the top. Interestingly, stronger methods are almost always more usable.

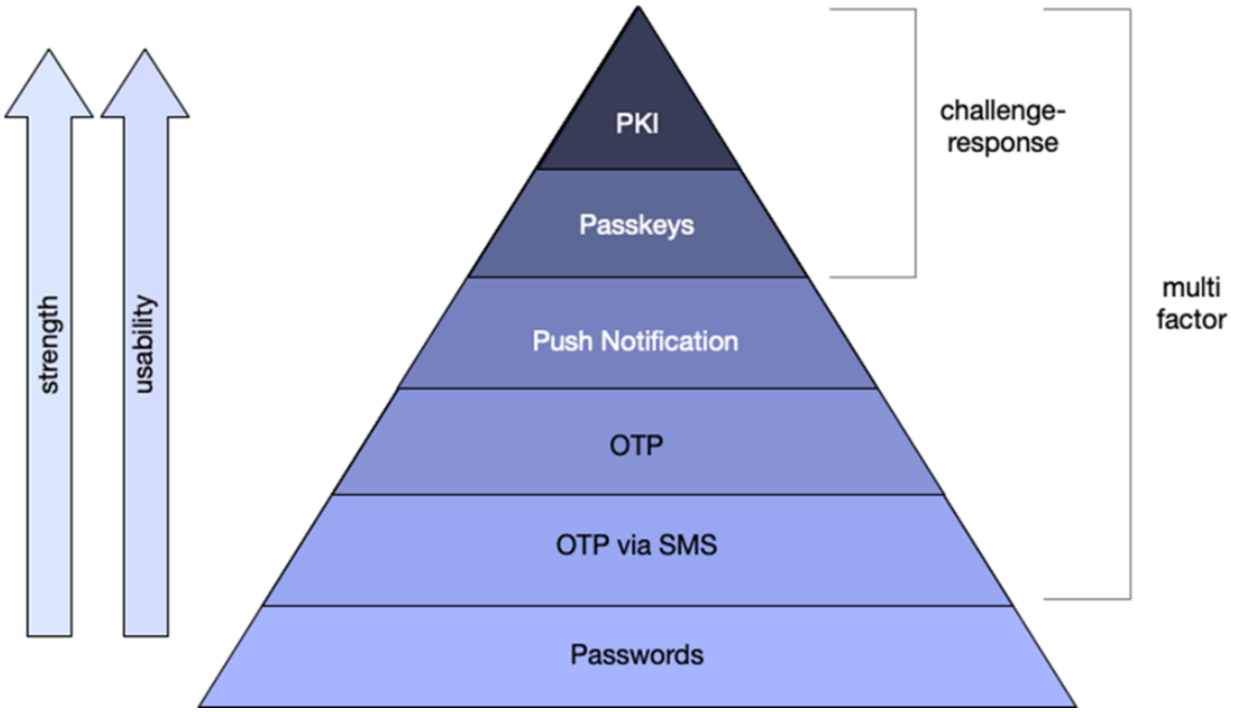


Figure 3.9 The strength and usability pyramid for authentication methods. As you ascend the pyramid, authentication mechanisms become more resistant to phishing, replay attacks, and credential theft—though some may require a more technical setup or infrastructure. Passwords, located at the base, offer poor security and usability, while challenge-response methods like passkeys and PKI provide high assurance with an improved user experience. Multi-factor approaches (MFA) are positioned across the middle tiers, balancing security and usability by combining various types of factors.

I've left identifier-only authentication off the pyramid due to security concerns that limit its applications, despite its great usability. Token-based authentication could be placed at any level on the pyramid because its strength primarily depends on the initial authentication method used to issue the token.

Let's discuss the levels in the pyramid from bottom to top: